

Кібербезпека і загрози

Кібербезпека — це постійні зусилля щодо захисту окремих осіб, організацій та урядів від цифрових атак шляхом захисту мережесистем і даних від несанкціонованого використання або шкоди.

Рівні кібербезпеки складаються з:

- **Особистий**
 - На особистому рівні вам необхідно захищати свій обліковий запис, дані та електронні пристрої.
- **Корпоративний**
 - На корпоративному рівні відповідальність кожного співробітника полягає в захисті репутації організації, її даних та клієнтів.
- **Урядовий**
 - Оскільки все більше цифрової інформації збирається та розповсюджується, її захист стає ще важливішим на рівні уряду, де на карті стоїть національна безпека, економічна стабільність, безпека та добробут громадян.



Традиційні дані

Дані про транзакції, як-от деталі, що стосуються купівлі та продажу, виробничої діяльності та основних корпоративних операцій, наприклад будь-яка інформація, яка використовується для прийняття рішень щодо працевлаштування.

Інтелектуальна власність, така як патенти, торгові марки та плани випуску нових продуктів, дозволяє підприємству отримувати економічні переваги над своїми конкурентами. Ця інформація часто вважається комерційною таємницею, і її втрата може виявитися катастрофічною для майбутнього компанії.

Фінансові дані, такі як звіти про доходи, балансові звіти та інформація про рух грошових коштів, дають уявлення про фінансовий стан компанії.

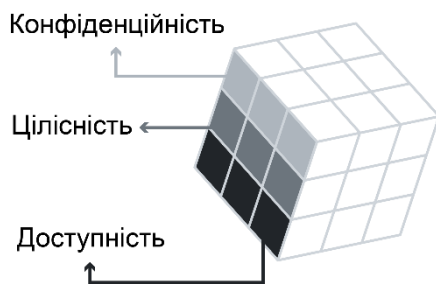


Інтернет речей (IoT) та великі дані

мережа фізичних об'єктів, таких як датчики, програмне забезпечення та інше обладнання. Усі ці «речі» підключені до Інтернету з можливістю збирати дані та обмінюватися ними. І враховуючи те, що можливості зберігання даних розширюються за рахунок хмари та віртуалізації, не дивно, що поява Інтернету речей призвело до експоненційного зростання обсягів даних, створивши нову сферу інтересів у технологіях та бізнесі під назвою «Великі дані».

Куб

Основні принципи захисту інформації

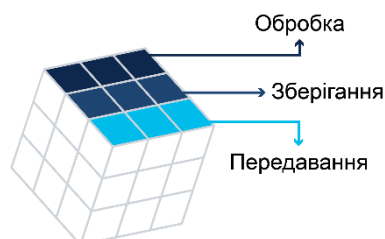


Конфіденційність запобігає розкриттю інформації неавторизованим особам

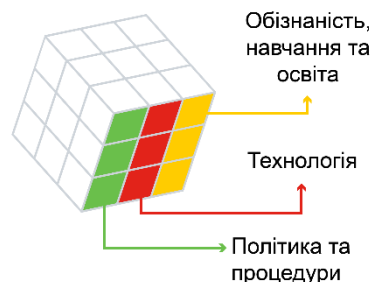
Цілісність забезпечує захист системної інформації або процесів від навмисних або випадкових змін. Одним із способів забезпечити цілісність є використання хеш-функції або контрольної суми.

Доступність означає, що авторизовані користувачі можуть отримати доступ до систем і даних, коли це необхідно, а ті, які не відповідають встановленим умовам, ні.

Захист інформації в кожному стані



Заходи безпеки, що застосовуються для захисту даних





Маршрутизатори

Маршрутизатори в основному використовуються для з'єднання різних сегментів мережі разом, вони зазвичай також забезпечують основні можливості фільтрації трафіку. Ця інформація може допомогти вам визначити, які комп'ютери з певного сегмента мережі можуть взаємодіяти і з якими сегментами мережі.



Міжмережні екрани

Міжмережні екрани можуть глибше вивчати сам мережний трафік і виявляти шкідливу поведінку, яку потрібно заблокувати. Міжмережні екрани можуть мати складні політики безпеки, які застосовуються до трафіку, який проходить через них.



Системи запобігання вторгнень

Системи запобігання вторгнень (IPS) використовують набір сигнатур трафіку, які відповідають шкідливому трафіку і атакам та блокують зв'язок при співпадінні.



Віртуальні приватні мережі

Системи віртуальних приватних мереж VPN дозволяють віддаленим співробітникам використовувати безпечний зашифрований тунель зі свого мобільного комп'ютера та безпечно підключатися до мережі організації. Системи VPN також можуть безпечно з'єднувати філії з мережею центрального офісу.

Міжмережні екрани

Міжмережний екран мережного рівня

Він фільтрує з'єднання на основі IP-адрес джерела та призначення.

Міжмережний екран транспортного рівня

Фільтрує з'єднання на основі портів джерела та призначення, а також станів з'єднання.

Міжмережний екран прикладного рівня

Фільтрує повідомлення на основі застосунку, програми чи служби.

Міжмережний екран на основі контексту

Фільтрує з'єднання на основі користувача, пристрою, ролі та профілю загроз.

Проксі сервер

Фільтрує запити веб-вмісту, наприклад URL-адреси, доменні імена та типи медіа.

Зворотній проксі-сервер

Розміщується перед веб-серверами і захищає, приховує, розвантажує та розподіляє доступ до веб-серверів.

Міжмережний екран NAT

Він приховує або маскує приватні адреси мережних вузлів.

Міжмережний екран на основі вузла

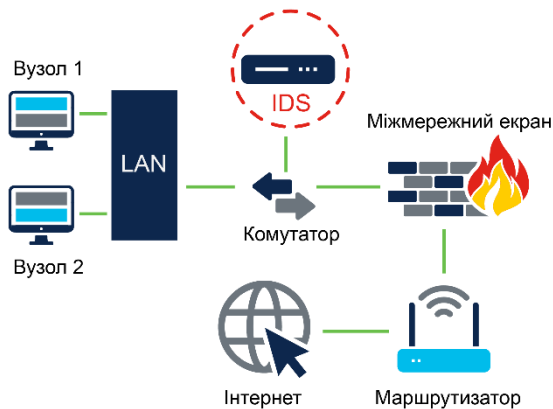
Фільтрує порти та виклики системних служб на одному комп'ютері.

Сканування портів

В мережах кожному застосунку, запущеному на пристрої, призначається ідентифікатор, який називається номером порта. Саме завдяки використанню цього номеру на обох кінцях сеансу зв'язку необхідні дані передаються до потрібного застосунку. Сканування портів - це процес зондування комп'ютера, сервера або іншого мережного пристрою для виявлення відкритих портів.

#NMAP PROJECT #Zenmap

IDS

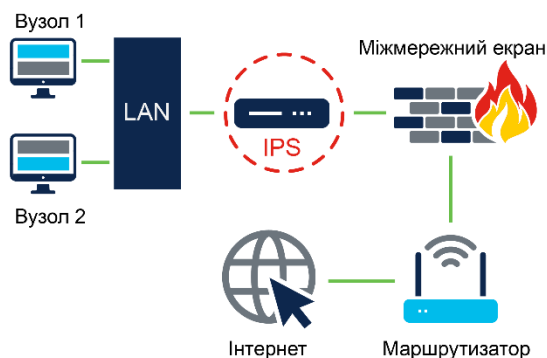


IDS може бути як виділеним мережним пристроєм, так і одним із кількох інструментів на сервері, міжмережному екрані чи навіть в операційній системі комп'ютера, наприклад Windows чи Linux, який сканує дані на основі бази даних правил чи сигнатур атак, шукаючи шкідливий трафік. При виявленні відповідності правилам або сигнатурам IDS реєструє виявлення атаки та створює попередження для мережного адміністратора.

Він не вживає заходів, а отже, не запобігає атакам. Завдання IDS - виключно виявлення, реєстрація та створення попередження.

Сканування, яке виконує IDS, уповільнює роботу мережі (відоме як затримка). Щоб запобігти затримці у мережі, IDS зазвичай розміщують офлайн (в автономному режимі), окремо від звичайного мережного трафіку. Дані копіюються або віддзеркалюються комутатором, а потім пересилаються до IDS для проведення аналізу в режимі офлайн.

IPS



IPS може блокувати або відхиляти трафік на основі спрацювання правила або при збігу сигнатури. Однією з найбільш відомих систем IPS/IDS є Snort. Комерційна версія Snort - це Cisco's Sourcefire. Sourcefire може у реальному часі виконувати аналіз трафіку і портів, ведення журналів, пошук і зіставлення контенту, а також виявлення спроб зондування, атак і сканування портів. Це рішення також інтегрується з іншими сторонніми інструментами для створення звітності, аналізу лог-файлів та продуктивності.

Найкращі практики безпеки

- Виконайте оцінку ризиків
 - Знання та розуміння цінності того, що ви захищаєте, допоможе виправдати витрати на безпеку.
- Розробіть політики безпеки
 - Створіть політику, яка чітко окреслює правила організації, посадові ролі, а також відповідальність і очікування для співробітників.
- Заходи фізичної безпеки
 - Заходи фізичної безпеки – обмежте доступ до комунікаційних шаф, серверних кімнат, а також до систем пожежогасіння.
- Заходи з управління людськими ресурсами
 - Необхідно виконати перевірку даних всіх співробітників.
- Виконайте перевірку резервних копій
 - Виконайте регулярне резервне копіювання та тестування відновлення даних з резервних копій.
- Встановлення виправлень та оновлень, пов'язаних з безпекою
 - Регулярно оновлюйте операційні системи та програми сервера, клієнта та мережного пристрою.
- Використовуйте засоби контролю доступу
 - Налаштуйте ролі і рівні привілеїв користувачів, а також надійну автентифікацію.
- Регулярно перевіряйте реагування на інциденти
 - Використовуйте команду з реагування на інциденти та перевіряйте сценарії реагування на надзвичайні ситуації.
- Впроваджуйте моніторинг мережі, аналітику та інструменти керування
 - Виберіть рішення для моніторингу безпеки, яке інтегрується з іншими технологіями.
- Встановіть пристрої захисту мережі
 - Використовуйте маршрутизатори, міжмережні екрани та інші пристрої безпеки нового покоління.
- Впроваджуйте комплексні рішення безпеки кінцевих вузлів
 - Використовуйте антизловмисне і антивірусне програмне забезпечення корпоративного рівня.
- Навчайте користувачів
 - Забезпечте навчання працівників процедурам безпеки.
- Шифруйте дані
 - Шифруйте всі конфіденційні дані компанії, включно з електронною поштою.

Правила вибору паролів

- Паролі повинні містити не менше восьми символів, але не більше 64 символів.
- Не слід використовувати паролі, які легко вгадати, такі як «пароль» або «abc123».
- Не повинно бути жодних правил композиції, наприклад, включати малі та великі літери та цифри.
- Користувачі повинні мати можливість бачити пароль під час введення, щоб підвищити точність.
- Дозволяється використовувати усі друковані символи та пробіли.
- Підказок на пароль бути не повинно.
- Термін дії пароля повинен бути відсутній.
- Не повинно бути аутентифікації на основі знань, наприклад, надання відповідей на секретні запитання або перевірка історії транзакцій.

рекомендації мають на меті покласти відповідальність за перевірку користувачів на постачальників послуг і забезпечити кращий досвід для користувачів загалом.

#NIST

Типи шкідливого програмного забезпечення



Шпигунське ПЗ

Шпигунське програмне забезпечення (Spyware), розроблене для відстеження та шпигування за вами, відстежує вашу активність в Інтернеті та може реєструвати кожну клавішу, яку ви натискаєте на клавіатурі, а також фіксувати майже будь-які ваші дані, включаючи конфіденційну особисту інформацію, як-от ваші онлайн-банківські реквізити.

Шпигунське програмне забезпечення робить це, змінюючи налаштування безпеки на ваших пристроях.

Воно часто поєднується з легальним програмним забезпеченням або троянськими конями.



РЕКЛАМНЕ ПЗВ

Рекламне програмне забезпечення (Adware) часто встановлюється разом із деякими версіями програмного забезпечення і призначене для автоматичної доставки реклами користувачеві, найчастіше у веб-браузері. Ви визнаєте це, коли побачите! Важко ігнорувати, коли ви стикаєтеся з постійною виринаючою рекламою на екрані.

Зазвичай рекламне ПЗ постачається разом із шпигунським ПЗ.



ЗАДНІ ДВЕРІ

Цей тип зловмисного програмного забезпечення використовується для отримання несанкціонованого доступу в обхід звичайних процедур автентифікації для доступу до системи. В результаті хакери можуть отримати віддалений доступ до ресурсів застосунку та виконувати віддалені системні команди.

Бекдор працює у фоновому режимі, і його важко виявити.



Руткіт

Це шкідливе програмне забезпечення призначене для модифікації операційної системи, щоб створити бекдор, який зловмисники потім можуть використовувати для віддаленого доступу до вашого комп'ютера. Більшість руткітів використовують вразливості програмного забезпечення, щоб отримати доступ до ресурсів, які зазвичай не повинні бути доступні (підвищення привілеїв), і змінити системні файли.

Руткіти також змінюють системні інструменти експертизи та моніторингу, що дуже ускладнює виявлення цього зловмисного ПЗ. У більшості випадків комп'ютер, заражений руткітом, потрібно очистити й перевстановити необхідне програмне забезпечення.



ПРОГРАМ-ВИМОГАЧ

Зловмисне ПЗ (Ransomware), призначене для блокування комп'ютерної системи або даних до моменту отримання викупу. Програми-вимагачі зазвичай працюють, шифруючи ваші дані, щоб ви не могли отримати до них доступ.

Деякі версії програм-вимагачів можуть для блокування системи використати її певні вразливості.



ТРОЯНСЬКИЙ КІНЬ



ВІРУС



ЧЕРВИ

Вірус – тип комп'ютерної програми, яка під час виконання реплікується та приєднується до інших виконуваних файлів, наприклад документа, шляхом вставки власного коду. Більшість вірусів вимагають взаємодії з кінцевим користувачем для активації

Троянський кінь – шкідливе програмне забезпечення, що експлуатують привілеї користувача і найчастіше зустрічаються у файлах зображень, аудіофайлах або іграх. На відміну від вірусів, трояни не само-розмножуються, а діють як приманка для проникнення шкідливого програмного забезпечення минаючи нічого не підозрюючих користувачів.

Інтернет-хробаки – тип зловмисного програмного забезпечення, яке само-розмножується, щоб поширюватися з одного комп'ютера на інший. На відміну від вірусу, хробаки можуть запускатися самостійно.

Шифрування

Шифрування – це перетворення інформації у форму, непридатну для сприйняття неавторизованою стороною. Лише довірена, уповноважена особа, яка має секретний ключ або пароль, може розшифрувати дані та отримати їх в оригінальній формі.

Зауважте, що саме лише шифрування не може завадити перехопленню даних. Воно може тільки завадити неавторизованій особі переглядати або отримувати доступ до вмісту даних

Безпека бездротової мережі

Бездротові мережі надають можливість пристроям підключитися до мережі, використовуючи ідентифікатор мережі, відомий як Service Set Identifier (SSID). Хоча бездротовий маршрутизатор можна налаштувати так, щоб він не транслював SSID, це не слід вважати достатньою безпекою для бездротової мережі.

Хакери будуть знати про попередньо встановлений SSID і пароль за замовчуванням. Тому ці дані слід змінити, щоб запобігти проникненню зломисників у вашу домашню бездротову мережу. Крім того, слід шифрувати бездротове з'єднання, активувавши бездротову безпеку та функцію шифрування WPA2 на вашому бездротовому маршрутизаторі. Але майте на увазі, навіть якщо ввімкнено шифрування WPA2, бездротова мережа все ще може бути вразливою.

KRACK – атака перевстановлення ключів. Простіше кажучи, зломисники порушують шифрування між бездротовим маршрутизатором і бездротовим пристроєм, що дає їм доступ до мережних даних.

Соціальна інженерія

Соціальна інженерія – це маніпулювання особою задля спонукання її до виконання певних дій або розголошення конфіденційної інформації.



Вигаданий привід (Pretexting)

Це метод, коли зловмисник телефонує конкретній особі і обманом намагається отримати доступ до привілейованих даних. Наприклад, прикидатися, що потрібні особисті чи фінансові дані, щоб підтвердити її особу.



Упасти на хвіст (Tailgating)

Це коли зловмисник швидко слідує за уповноваженою особою в захищене місце розташування.

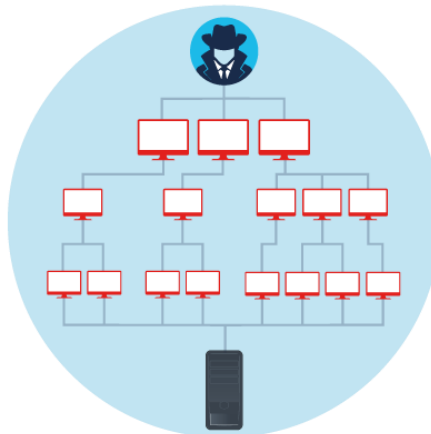


Послуга за послугу (quid pro quo)

Це коли зловмисник запитує персональну інформацію від особи в обмін на щось, наприклад, безкоштовний подарунок.

Відмова в обслуговуванні (DoS)

Атаки відмови в обслуговуванні (DoS) – це тип мережевої атаки, яку відносно легко може здійснити навіть некваліфікований зловмисник. Результатом DoS-атаки є переривання роботи мережних сервісів для користувачів, пристроїв або застосунків.



Перевантаженість трафіку

Це коли мережа, комп'ютер або програма надсилає величезну кількість даних зі швидкістю, з якою неможливо їх обробити. Це спричиняє затримку передачі чи відповіді, або аварійне завершення роботи пристрою чи сервісу.

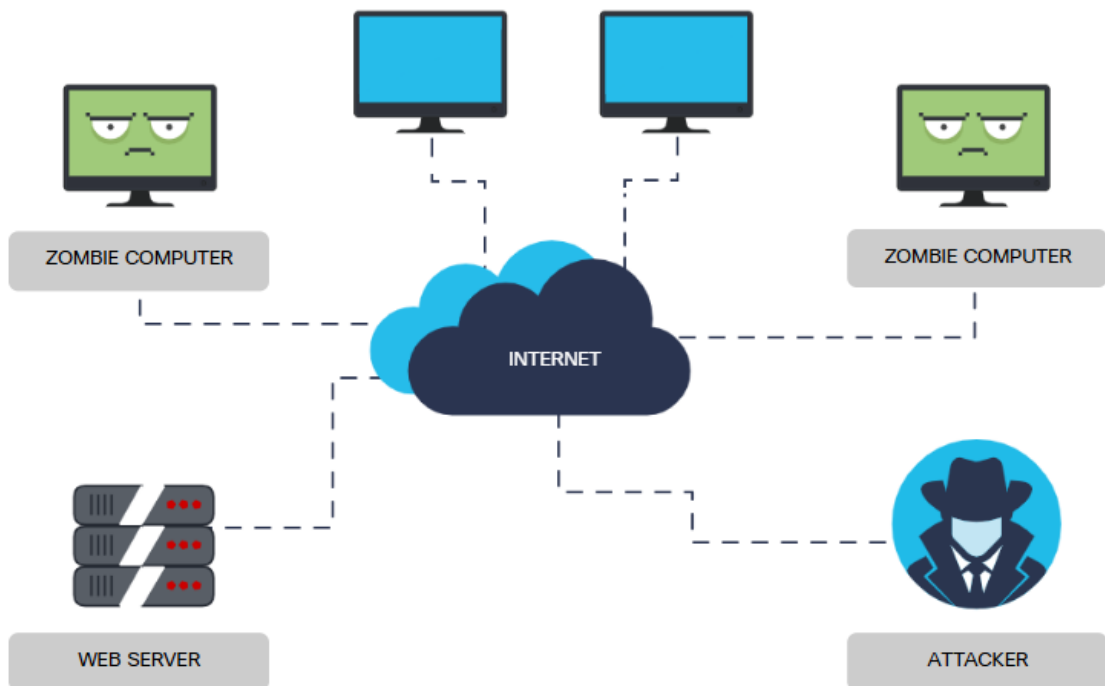
Зловмисно відформатовані пакети

Пакет – це набір даних, що передається між джерелом і одержувачем - пристроєм або програмою через мережу, наприклад Інтернет. Коли зловмисно сформований пакет надсилається одержувачу і він не може його обробити.

Розподілений DoS (DDoS)

Розподілена DoS атака (DDoS) подібна до атаки DoS, але вона походить від декількох скоординованих джерел. Наприклад:

- Зловмисник будує мережу (ботнет) із заражених вузлів, які називаються зомбі, які контролюються системами керування.
- Комп'ютери-зомбі будуть постійно сканувати та заражати все більше вузлів, створюючи все більше і більше зомбі.
- Коли ботнет буде готовий, хакер дасть інструкцію системам керування, щоб змусити ботнет зомбі здійснити DDoS-атаку.



Ботнет

Бот-комп'ютер зазвичай заражається в наслідок відвідування веб-сайту, відкриття вкладки електронної пошти або через заражений медіа-файл. Ботнет - це група ботів, з'єднаних через Інтернет, які можуть контролюватися одним зловмисником або групою. У ньому можуть бути десятки тисяч або навіть сотні тисяч ботів, які зазвичай керуються через сервер команд та керування. Ці боти можуть активуватися для розповсюдження шкідливого програмного забезпечення, запуску DDoS-атак, розповсюдження спаму або виконання атаки підбору пароля методом «грубої сили»

Атаки на шляху

Зловмисники на шляху інформації перехоплюють або змінюють зв'язок між двома пристроями, такими як веб-браузер і веб-сервер, щоб зібрати інформацію або видавати себе за один із пристроїв.



Атака MitM відбувається, коли кіберзлочинець отримує контроль над пристроєм без відома користувача. За допомогою такого рівня доступу зловмисник може перехоплювати та підмінювати інформацію користувача.

Варіант атаки "Людина посередині", MitMo - це тип атаки, який використовується для отримання контролю над мобільним пристроєм користувача. При зараженні мобільний пристрій отримує інструкцію вилучити конфіденційну інформацію користувача та надіслати її зловмисникам. Zeus є одним із прикладів пакета шкідливих програм.

Атаки на паролі

- Розпилення пароля
 - Техніка намагається отримати доступ до системи шляхом «розпорошення» кількох часто використовуваних паролів на велику кількість облікових записів
- Атаки за словником
 - Хакер систематично пробує кожне слово в словнику
- Атаки грубої сили
 - Зловмисник використовує всі можливі комбінації літер, цифр і символів у просторі для паролів
- Атаки веселки
 - Атака порівнює хеш пароля з тим, що зберігається в таблиці веселки
- Перехоплення трафіку